

Computer and Network Security

Lab 02 (“Going Undercover”)

Disclaimer. Hacking without permission is illegal. These labs are strictly educational for learning about cyber-security in the areas of ethical hacking and penetration testing so that we can protect ourselves against the real hackers. Hence, any attack technique, tools, and technology, learned during these labs should only be launched on systems you either own or have permission to launch attacks on. Don't wrong your classmates by launching attacks against them—they will know in the judgement day and you will pay for that. Please be professional, wise, and mature.

Lab Note. In Lectures 3 and 4, you studied spoofing attacks, in which an attacker pretends to be a legitimate network resource in order to bypass security restrictions and access system services without authorization or cost. In this lab, you will learn how easy it is to implement such attack vector. You will be conducting various spoofing attacks on different network services and learn how to protect yourselves from those miscreants who daily perform these attacks on normal people.

Description. In this lab, you will perform some spoofing attacks (a.k.a., impersonation attacks). You will spoof email addresses (email spoofing), websites, MAC addresses, and identities. You will spoof the local gateway through a man-in-the-middle configuration. You will learn how to protect against all these attacks.

To rock this lab out, make sure to have:

- A computer running Kali GNU/Linux.
- The Social-Engineering Toolkit installed (installed by default in Kali Linux).
- The macchanger tool installed (installed by default in Kali Linux).
- Ettercap installed (installed by default in Kali Linux).
- Basic understanding of what social-engineering is and their techniques.

Task 1 (Spoofing emails through unknown SMTP servers)

1. Go to Emikei's mailer web-application at <https://emkei.cz/>.
2. Use the application to send some spoofed emails (e.g., from whoever you want `@ensia.edu.dz`). One email to your ensia account, and others to other mail accounts (not Gmail-based accounts— as `ensia.edu.dz` is).
3. Once received (check the spam folder), view the email options and select “Show Original” (“Message Source” on Microsoft Outlook or “Message Header” on Proton Mail). This option will display all information about the email, including the smtp servers the email went through, the IP of the source, and identity of the source server, and more. Read the content of the email header and try to find evidences that the email is a spoofed one. Also, you can copy then paste the email header in one of the email tracing web-apps:
 - The web-app at <https://www.ip2location.com/free/email-tracer> will trace the email and show you the path it took from the original SMTP server to your account.
 - The web-app at <https://whatismyipaddress.com/trace-email> will trace the email and reveal useful information, such as the IP address of the original server.
4. Go back to the email original header and look for information related to the following attributes: DKIM, DMARC, SPF, and ARC. What do you conclude?
 - SPF (Sender Policy Framework) – verifies that the sending mail server is authorized to send email for (on behalf) a domain.
 - DKIM (DomainKeys Identified Mail) – uses cryptographic signatures to ensure the email was not modified and is from the claimed domain.
 - DMARC (Domain-based Message Authentication, Reporting & Conformance) – combines SPF and DKIM and defines policy actions if checks fail (none, quarantine, reject).
 - ARC (Authenticated Received Chain) – preserves authentication results as an email passes through intermediate servers (e.g., mailing lists, forwarders), preventing false DMARC failures.

Task 2 (Spoofing websites with SET)

In this part, you are going to use **SET** tool to create a fake clone of a website. Let us take the LinkedIn website <https://www.linkedin.com/> as our target.

1. Run the SET tool again, then choose “Social-Engineering Attack”.
2. Then, choose Option 2: “Website Attack Vectors”
3. Then, choose Option 3: “Credentials Harvester Attack Method”
4. Then, choose Option 2: “Site Cloner”.
5. Type in the IP address of the local computer (`$ifconfig`).
6. Enter the URL to clone: `https://www.linkedin.com/`
7. Now, the website is cloned and a webserver is running on the local computer.
8. Next, take the IP address of the computer (above) and use [url shortener app](#) to create a shortened “hidden” URL. If for instance your IP address is 192.168.1.5, then input `http://192.168.1.5` as input to shorten.
9. Send a spoofed email to your classmate (via **turbosmtp**), who should be connected on your local network while making sure to invite them to click on the link you made in Step 8.

When your classmate clicks on the link, their browser should open the spoofed webpage. They can input some fake LinkedIn credentials (Email or phone, and password) and click on “Sign In”. You should capture the credentials on your SET interface.

You may have noticed that on the spoofed emails, if you hover on the shortened link, the same link is displayed on the bottom-left side of your browser. This is very tricky. You can unshorten a URL to determine the real and original URL [here](#).

Task 3 (Spoofing MAC addresses with `macchanger`)

You were informed that a free Wi-Fi network is available. However, the Wi-Fi access point is adopting MAC address filtering. The list of authorized MAC addresses got leaked [here](#).

1. Try to connect to this wireless access point or wireless router (SSID: **LAB AI388** & WPA2 password: **ensiaAI388**). You should fail as you are not allowed.
2. Use **`macchanger`** utility to change your MAC address into one of the authorized addresses. To do that, make sure your Ethernet card is down (i.e., if your network card is **`wlan0`** then run **`$ifconfig wlan0 down`**) when changing the MAC address. Once changed, turn your card up (**`$ifconfig wlan0 up`**).
3. Try to connect this time to the access point. You should succeed now.
4. Try to connect two computers using the same MAC address. What happens? How do you think we can detect this malicious activity? Discuss.

Task 4 (Spoofing Identities) — to be done in the Lecture

This task will be conducted during the lecture. You will learn how to:

1. Create clones of RFID-based cards, like your student card. You will learn the different technologies and ways to protect against card spoofing.
2. Create clones of RFID-based keyfobs, like your apartment building keyfob. You will learn the different technologies and ways to protect against keyfob cloning.
3. Create true clones of banking cards that use the magnetic-strip to make commercial payments. You will learn how to protect yourselves from skimming attack.

Task 5 (Man In The Middle)

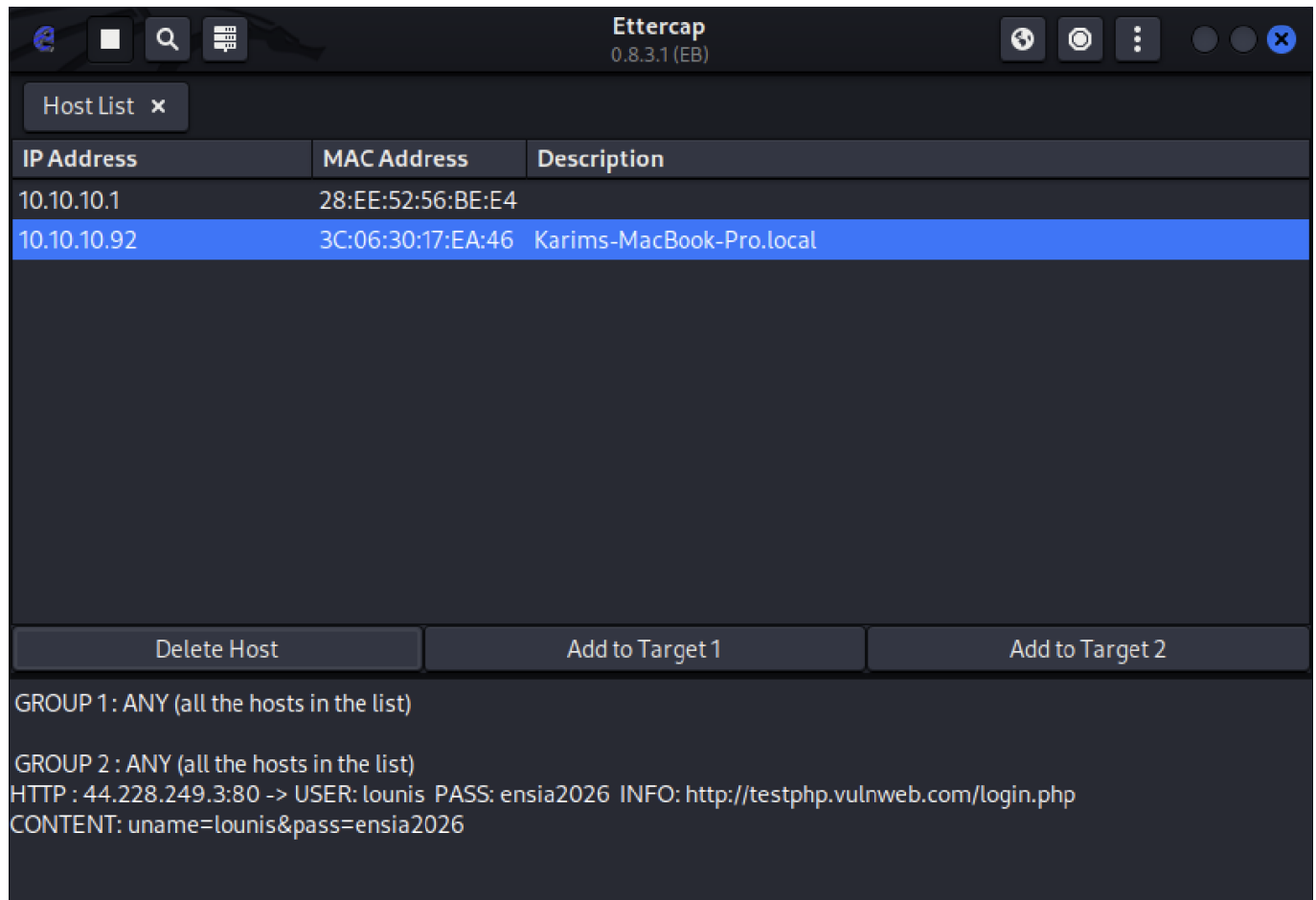
In this part, you are going to learn a very important attack vector— Man In The Middle (MITM). To conduct this attack on a local network (LAN), you will first have to perform an ARP poisoning attack— corrupting the ARP cache of other computers in your LAN by sending them fake ARP packets, informing them that you (the attacker computer) is the gateway— hence, redirecting traffic to your computer.

To launch the attack, you will have to identify three main components: the victim computer running whatever operating system (and their IP address), the gateway (and their IP address), and the attacker computer running Kali Linux system. The aim of the attack is to spoof the gateway to make the victim computer believe that you “the attacker” is the gateway by flooding the network with fake ARP packets.

To that end, follow the below steps:

1. Write down the IP addresses of the gateway and the victim computer.
2. Make sure the victim computer has access to the Internet.
3. On Kali Linux start **Ettercap-graphical** software tool.
4. Keep the options **Sniffing startup** and **Primary Interface** as they are. Make sure that the selected interface is the one you are using on the LAN.
5. Click on the checkmark to accept the configuration. The unified sniffing will start. Then, click on the **ettercap menu > Hosts > scan for hosts**. This will identify the computers in your local network. Next, click on **Host list** to display the identified computers. You should see different hosts with their IP addresses, MAC addresses, and a description (hostname).
6. Click on the gateway line then click on **Add Target 1**. Next, click on the target computer line then click on **Add Target 2**.
7. Click on the **MITM menu** (look for earth icon) and select **ARP poisoning**. Select **sniff remote connections** and hit Ok.
8. On your victim computer, display the ARP cache (**arp -a**) and check that the MAC address of the gateway is not the MAC address of the attacker.

9. On your victim computer, visit this website, input a **username** and **password** then submit. The packets will go to the attacker before they go to the gateway.
10. You will see on **Ettercap** GUI that the credentials, the website URL, the website and IP address, were captured, as show below. You can also run **Wireshark** and see that you are receiving the packets destined to the victim.



Challenge 1 (Spoofing DNS servers)

In this part, you are challenged to add another set of steps to the previous task to perform DNS spoofing attack. As you stand in the middle, you are asked to respond to the DNS requests sent by the victim with your IP address (the one of the Kali) while running an **Apache** service with customized scary index webpage. When the victim types **www.google.com**, their browser opens the scary website. Also, on the victim computer, if they type **dig -t A www.google.com**, the result of the query will be the IP address of the attacker.

If you want to solve this challenge, create a demo video, upload it to Youtube, and send me the link. The first 5 students are rewarded. And same thing for Challenge 2.

Challenge 2 (Spoofing emails through open SMTP relay servers)

In this part, you are challenged to use an **open** SMTP relay server to send emails. That is, you will search online for and use an open SMTP relay to send emails from, for arbitrary source and destination email addresses. Last years, we used **postmark** and **turbosmtp** mailing companies and went through their open SMTP relays to easily send spoofed emails (cf., video). However, these companies have recently enabled certain security measures and transformed their open relay into a **closed** relay. In a closed relay, you are required by the company to prove the ownership of the domain you are sending from, which is not the case with open SMTP relays (e.g., Task 1).

If you manage to find one, then you will have to create an account using your ensia email (or other accounts of yours), confirm the registration, and receive an email that generally contains all the required information about the relay (i.e., server name, password, etc). Once done, you will use the Social-Engineering Toolkit (SET) to connect to the relay and send emails. If you are running Kali GNU/Linux, then the software is pre-installed. If you are using another Linux operating system, you will need to install it. To send a spoofed email using SET through the open SMTP relay, you need to perform the following (you can watch the video for a better tutoring):

1. Run SET and choose Option 1 “Social-Engineering Attacks”, then Option 5 “Mass Mailer Attack”, then Option 1 “Email Attack Single Email Address”.
2. Insert the ensia email address of your classmate.
3. Choose Option 2 “Use your own server or open relay”
4. Insert you email address (validated one) and the sender name “FROM NAME”.
5. Insert the username and password of the relay server. Then, insert the SMTP email server address, and the port (generally, 25 or 587).
6. Continue filling out the options, and body of the email, then send it.
7. If successfully send the tool displays “[*] SET has finished sending the emails”.

Once the email is received by your classmate, ask them to open the email (**on their account, forwarding account, and smartphone account**) to perform the analysis you did in Task 1. Note the **via** keyword. What do you observe and conclude for each particular receiving account?